

CI/CD / DEVOPS / БЕЗОПАСНОСТЬ

## Атака на прт, превратившая подтверждение происхождения в камуфляж

Червь, похищающий учетные данные, затронул более 400 пакетов прт через украденные токены разработчиков, выявив уязвимости в безопасности доверенных публикаций и конвейеров непрерывной интеграции.

7 августа 2026 года, 14:31 [Аманда Касвелл](#)



Исследователи в области безопасности на этой неделе сообщили об атаке на цепочку поставок прт, затронувшей более 400 пакетов, в том числе проекты, связанные с Keuv и Cacheable. Злоумышленники использовали украденные учетные данные разработчиков для публикации вредоносных версий.

Этот инцидент, судя по всему, указывает на тенденцию в сфере безопасности программного обеспечения: злоумышленники нацеливаются на разработчиков и рабочие процессы, которым уже доверяют при публикации.

---

процессы, которым уже доверяли при публикации.

---

## Червь распространяется через учетные данные

По данным **Microsoft Threat Intelligence**, вредоносные выпуски содержали вариант червя Mini Shai-Hulud, который крадет учетные данные. При распространении они обходили исходные репозитории и начинали работу с украденных учетных данных сопровождающих. После этого червь искал на компьютерах разработчиков и в средах непрерывной интеграции любые другие учетные данные, которые можно было использовать.

Обнаружив активный токен публикации npm, он загрузил последнюю версию каждого пакета, к которому у аккаунта был доступ, внедрил вредоносный хук жизненного цикла preinstall, изменил номер патча и опубликовал зараженные версии. Поскольку npm автоматически запускает хуки preinstall до завершения установки, вредоносное ПО могло начать работать на рабочих станциях разработчиков и **в CI-средах** до начала тестирования приложений или проверки безопасности.

---

Поскольку npm автоматически запускает хуки предварительной установки до завершения установки, вредоносное ПО может начать работать на рабочих станциях разработчиков и в системах непрерывной интеграции до начала тестирования приложений или проверки безопасности.

---

## Предварительная установка хуков обеспечивает бесшумное выполнение

В средах непрерывной интеграции он оставался подключенным к активному заданию, откуда мог получать доступ к секретам рабочего процесса, учетным данным исполнителя и разрешениям на публикацию. На рабочих станциях он мог продолжать работать в фоновом режиме и внедрять файлы запуска в Visual Studio Code и **Claude**, включая .vscode/tasks.json и .claude/settings.json.

---

может запрашивать собственный краткосрочный токен вместо того, чтобы красть долгосрочные учетные данные для публикации. В результате вредоносный пакет может даже содержать действительные **подтверждения происхождения**.

## Provenance не гарантирует целостность

Эта кампания показывает, как быстро атака может распространиться с компьютера разработчика на весь процесс выпуска. Общие системы непрерывной интеграции создают еще одну уязвимость, поскольку GitHub Actions может повторно использовать зависимости при выполнении рабочих процессов. **Документация** GitHub предупреждает, что эти кэшированные файлы не подписаны и не проверены.

The lesson for engineering teams is to keep publishing access away from the parts of the pipeline that install dependencies. The principle of restricting what automated processes can do echoes **a bigger trend in how the industry is rethinking blanket permissions for AI-assisted coding**.

### TRENDING STORIES

1. [Improving Developer Experience Drives Profitability](#)
2. [The npm attack that turned provenance attestations into camouflage](#)
3. [Fixing Engineering's Biggest Time Suck: Finding Information](#)
4. [Your Recovery Timeline Is a Lie: Why They Fall Apart](#)
5. [AI Combined With Agile Lets Developers Focus on Craft](#)

---

This campaign shows how quickly an attack can move from a developer's machine into the rest of the release process.

---

late publishing from dependency installation

installed.

Rotating the stolen token **may not be enough** once a compromised package has run its lifecycle scripts. Teams may also need to rebuild affected machines and base images, clear shared caches and recreate software artifacts from trusted dependencies.

TNS



Amanda Caswell is an AI journalist, certified prompt engineer, and technology commentator whose work and expertise have been featured on Fox News and CBS News. She covers artificial intelligence, developer tools, foundation models, and emerging technologies, with a particular focus...

[Read more from Amanda Caswell →](#)

#### SHARE THIS STORY



#### TRENDING STORIES

1. Improving Developer Experience Drives Profitability
2. The npm attack that turned provenance attestations into camouflage
3. Fixing Engineering's Biggest Time Suck: Finding Information
4. Your Recovery Timeline Is a Lie: Why They Fall Apart
5. AI Combined With Agile Lets Developers Focus on Craft

#### INSIGHTS FROM OUR SPONSORS

10 Years of MongoDB Atlas. Built for What's Next

25 June 2026

## Build Trust in Agentic AI: From POC to Production

23 June 2026

## Production-Ready Agents Need A Production-Ready Data Platform

11 June 2026



## End-to-End DevOps: Evolving Strategies & Automation Trends

26 January 2024

## CTO Insights Unveiled – Unlocking Tech Leadership Excellence at Plato Elevate

10 November 2023

## How the Terraform License Change Impacts Your DevOps

21 September 2023



## Octopus Easy Mode - Progressive Rollout

7 August 2026

## How to Stream Octopus Audit Logs to Grafana Cloud With OpenTelemetry

6 August 2026

## MCP Easy Mode

5 August 2026

# most recent TNS articles in your inbox each day.

svo1975pvn1982@gmail.com

SUBSCRIBE

The New Stack does not sell your information or share it with unaffiliated third parties. By continuing, you agree to our [Terms of Use](#) and [Privacy Policy](#).

## ARCHITECTURE

Cloud Native Ecosystem  
Containers  
Databases  
Edge Computing  
Infrastructure as Code  
Linux  
Microservices  
Open Source  
Networking  
Storage

## ENGINEERING

AI  
AI Engineering  
API Management  
Backend development  
Data  
Frontend Development  
Large Language Models  
Security  
Software Development  
WebAssembly

## OPERATIONS

AI Operations  
CI/CD  
Cloud Services  
DevOps  
Kubernetes

## CHANNELS

Podcasts  
Ebooks  
Events  
Webinars  
Newsletter

### THE NEW STACK

[About / Contact](#)  
[Sponsors](#)  
[Advertise With Us](#)  
[Contributions](#)



Community created roadmaps, articles, resources and journeys for developers to help you choose your path and grow in your career.

[Frontend Developer Roadmap](#)  
[Backend Developer Roadmap](#)  
[Devops Roadmap](#)

### FOLLOW TNS



© The New Stack 2026

[Disclosures](#)  
[Terms of Use](#)  
[Advertising Terms & Conditions](#)  
[Privacy Policy](#)  
[Cookie Policy](#)